# Analyse Stratégique de la Cybersécurité : L'Impact de WannaCry

*UE SEC102 – CNAM Nouvelle Aquitaine*

**L'Évolution des Menaces Globales**

## Résumé Exécutif

L'attaque par rançongiciel WannaCry de mai 2017 représente un tournant majeur dans l'histoire de la cybersécurité mondiale, illustrant la vulnérabilité des infrastructures critiques, particulièrement le National Health Service (NHS) au Royaume-Uni. Exploitant la faille **EternalBlue** développée par la NSA et divulguée par les **Shadow Brokers**, ce "ver de rançongiciel" a infecté plus de 200 000 ordinateurs dans 150 pays en l'espace de quelques heures.

L'analyse des données met en évidence un impact financier et opérationnel considérable : une baisse de 6 % des admissions dans les hôpitaux infectés et un coût estimé pour le NHS s'élevant à 92 millions de livres sterling. Attribuée au **Groupe Lazarus**, soutenu par la Corée du Nord, cette attaque souligne l'émergence de menaces persistantes avancées (APT) motivées par le chaos systémique ou le gain financier. En réaction, les cadres législatifs mondiaux, tels que le **Computer Fraud and Abuse Act (CFAA)** aux États-Unis et la directive **NIS2** en Europe, évoluent pour renforcer la résilience et imposer des normes de reporting plus strictes, marquant la fin d'une ère d'innocence numérique.

---

## 1. L'Attaque WannaCry : Mécanismes et Conséquences

### 1.1 Fonctionnement Technique et Propagation

WannaCry se distingue par sa nature hybride de rançongiciel et de ver. Contrairement aux rançongiciels traditionnels nécessitant une action de l'utilisateur (phishing), WannaCry s'est propagé de manière autonome via les réseaux.

- **Vecteurs d'attaque :** Utilisation de l'exploit **EternalBlue** ciblant le protocole **SMBv1** de Microsoft Windows. Cet exploit permet de se déplacer latéralement dans les intranets sans intervention humaine.
- **Composants internes :** Le malware comprenait un module de chiffrement/déchiffrement, une copie du logiciel Tor pour l'anonymat et des clés de cryptage.
- **Le "Kill Switch" :** L'attaque a été freinée par le chercheur Marcus Hutchins, qui a enregistré un domaine non existant (iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com) interrogé par le virus avant son exécution. L'obtention d'une réponse de ce domaine entraînait l'arrêt automatique du malware.

### 1.2 Impact sur le National Health Service (NHS)

Bien que le NHS n'ait pas été la cible directe, il en fut l'une des principales victimes en raison de l'utilisation massive de systèmes obsolètes (Legacy), notamment Windows XP.

| Indicateur d'Impact | Données Constatées (Hôpitaux infectés) |
|---|---|
| **Établissements touchés** | 34 trusts infectés, 46 affectés par des mesures préventives. |
| **Volume d'admissions** | Diminution de 6 % des admissions totales par jour. |
| **Urgences (A&E)** | Baisse de 6 % des fréquentations ; 5 hôpitaux ont dû détourner les ambulances. |
| **Rendez-vous annulés** | Environ 13 500 rendez-vous externes annulés dans les hôpitaux infectés. |
| **Coût financier (Activité)** | Perte estimée à 5,9 M£ en activité hospitalière directe. |
| **Coût total (Output)** | Estimé à 92 M£ incluant la perte de production et la récupération des données. |

**1.3 Mortalité et Sécurité des Patients**

L'analyse statistique n'a pas révélé d'augmentation significative de la mortalité durant la semaine de l'attaque. Cependant, la mortalité est considérée comme une mesure brute. Le préjudice subi par les patients inclut des retards dans les diagnostics (radiologie et pathologie inaccessibles) et des erreurs potentielles de dosage dues au retour forcé aux processus manuels sur papier.

---

## 2. Les Acteurs de la Menace : Le Groupe Lazarus

Le Groupe Lazarus (ou **Hidden Cobra**) est identifié comme une organisation de cybercriminalité d'État liée au gouvernement de la Corée du Nord. Son objectif est double : l'espionnage cybernétique et la génération de revenus illicites.

**2.1 Structure et Sous-unités**

- **BlueNorOff (APT38) :** Unité motivée par le gain financier. Responsable de cyber-braquages bancaires via la manipulation du réseau SWIFT (ex: tentative de vol de 1 milliard à la Bangladesh Bank en 2016, 81 M volés).
- **AndAriel :** Unité spécialisée dans la reconnaissance et le ciblage des infrastructures et du gouvernement de la Corée du Sud.

**2.2 Historique des Opérations Majeures**

1. **Operation Troy (2009-2012) :** Campagnes d'espionnage contre la Corée du Sud.
2. **Piratage de Sony Pictures (2014) :** Vol massif de données et fuite de films non sortis en réponse à un projet cinématographique parodiant le leader nord-coréen.
3. **Vols de Cryptomonnaies (2022-2023) :** Vol de 620 millions $ sur Ronin Network (Axie Infinity) et 100 millions $ sur Atomic Wallet.

---

## 3. Perspective Historique : Du Ver Morris à la Cyber-résilience

La compréhension des menaces actuelles s'appuie sur l'évolution des logiciels malveillants auto-réplicateurs.

**3.1 Le Ver Morris (1988)**

Considéré comme le premier logiciel malveillant à grande échelle sur ARPANET (précurseur d'Internet).

- **Auteur :** Robert Tappan Morris (étudiant à Cornell).
- **Mécanisme :** Exploitation de failles dans sendmail, finger et l'utilisation de mots de passe faibles.
- **Conséquence :** 10 % des 60 000 ordinateurs connectés à l'époque ont été paralysés par un déni de service involontaire (ré-infection multiple d'une même machine).
- **Héritage :** Cet événement a conduit à la création du premier **CERT** (Computer Emergency Response Team) et à la première condamnation sous le **CFAA**.

---

## 4. Cadre Réglementaire et Sécurité Publique

**4.1 Le Computer Fraud and Abuse Act (CFAA)**

Loi américaine de 1986 initialement conçue pour protéger les ordinateurs du gouvernement et des institutions financières. Elle a été élargie pour couvrir presque tout appareil connecté (y compris les téléphones portables).

- **Critiques :** Sa formulation large ("dépasser l'accès autorisé") a conduit à des poursuites controversées pour de simples violations de conditions d'utilisation (ex: affaire **Aaron Swartz**).
- **Évolution :** En 2021, la Cour Suprême des États-Unis (*Van Buren v. United States*) a restreint l'application du CFAA, excluant les cas où une personne accède à des informations auxquelles elle a normalement accès, mais pour une "mauvaise raison".

**4.2 Nouvelles Réglementations Mondiales (2024)**

Face à l'IA et aux menaces étatiques, les gouvernements durcissent les règles :

- **Directive NIS2 (UE) :** Impose aux entités critiques (santé, énergie) de signaler les incidents majeurs sous 24 heures.
- **Cyber Resilience Act (UE) :** Oblige les fabricants de produits numériques à garantir la sécurité tout au long du cycle de vie des produits.
- **Singapore OT Masterplan :** Renforce la sécurité des technologies opérationnelles (systèmes de contrôle industriel).

---

## 5. Recommandations pour la Résilience Numérique

Les sources s'accordent sur la nécessité d'un investissement soutenu dans la défense proactive.

- **Gestion des Correctifs (Patching) :** L'attaque WannaCry aurait pu être évitée si les systèmes avaient appliqué la mise à jour **MS17-010** publiée deux mois avant l'incident.
- **Défense en Profondeur :** Utilisation d'anti-malware à jour (ex: Windows Defender détectant Ransom:Win32/WannaCrypt) et blocage des protocoles obsolètes comme SMBv1.
- **Culture de Sécurité :** La cybersécurité doit être vue comme un "sport d'équipe" impliquant une éducation continue des employés sur le phishing et l'hygiène numérique.
- **Continuité d'Activité :** Développement de plans de gestion d'incidents robustes permettant de fonctionner en mode dégradé (processus manuels) lors d'une panne IT majeure.

| Action Préventive | Description |
|---|---|
| **Mise à jour Windows** | Installer les correctifs de sécurité critiques immédiatement. |
| **Segmentation réseau** | Isoler les systèmes critiques pour empêcher la propagation latérale des vers. |
| **Sauvegardes isolées** | Maintenir des sauvegardes déconnectées pour permettre une restauration sans payer de rançon. |
| **Hygiène des identifiants** | Supprimer les identifiants par défaut et imposer des mots de passe robustes. |